COMPLIANCE & SECURITY · TEMPLATE

Access Control and Offboarding Policy Template

For founders and operations leaders who need a clear, adoptable policy for granting, reviewing, and removing system access, for people and for machines.

> **How to use this:** Define your roles and access map first, including non-human accounts, then use the offboarding checklist as a same-day procedure whenever someone leaves or changes roles.

Role Definitions and Access Levels

Define the roles that exist in the company and what each should be able to access, independent of the people currently in them.

Role	Systems they need	Access level (View / Edit / Admin)	Approved by
Engineering			
Sales / Customer Success			
Finance / Billing			
Support			
Admin / Founder			

Current Access Map

List every system that holds sensitive data or controls, and who currently has access to it.

Production infrastructure / cloud environment: who has access?

Code repositories: who has access?

Customer data platform / CRM: who has access?

Billing and financial systems: who has access?

Email and core communication tools: who has admin rights?

© 2026 Rev-IQ. Free to use and adapt.

Non-Human Identities

Service accounts, API keys, OAuth grants, integrations and AI agents now often outnumber people. Each one needs an owner.

Account, key or connected app	What it can reach	Human owner	Expiry or review date

- [ ] Every service account, API key and integration has a named human owner.
- [ ] Credentials are unique per system; no key or token is shared between applications.
- [ ] AI assistants and agents connected to email, drives, code or the CRM are approved and scoped to the minimum they need.
- [ ] Third-party app grants (for example 'Sign in with Google' or Microsoft OAuth consents) are reviewed quarterly and unused ones revoked.

Access Request and Approval Process

- [ ] New access requests are submitted to a named approver, not granted informally.
- [ ] Access is granted at the minimum level needed for the person's role.
- [ ] Temporary or contractor access has a defined expiry date set when it is granted.
- [ ] Shared logins are avoided in favour of individual, attributable accounts.
- [ ] Admin accounts are separate from day-to-day accounts and use phishing-resistant MFA (passkeys or security keys) where supported.

Quarterly Access Review

- [ ] Review the full list of who has access to production systems and customer data.
- [ ] Confirm every admin-level account is still necessary and belongs to an active person.
- [ ] Review non-human identities and connected apps; revoke anything unused or unowned.
- [ ] Remove or downgrade any access that no longer matches the person's current role.

Same-Day Offboarding Checklist

Complete every item on the person's last working day, not after.

- [ ] Disable or remove email and core communication tool access.
- [ ] Remove access to code repositories and production infrastructure.
- [ ] Remove access to customer data platforms, CRM, and support tools.
- [ ] Remove access to billing, finance, and admin systems.

© 2026 Rev-IQ. Free to use and adapt.

- [ ] Revoke or rotate shared credentials, API keys and tokens the person had access to.
- [ ] Revoke OAuth grants, AI tool connections and agents the person set up, or transfer them to a new owner.
- [ ] Retrieve or remotely wipe company-managed devices.
- [ ] Confirm removal with a second person and log the date completed.

Where This Maps

Framework or obligation	Where this resource lines up
ASD Essentials for enterprise IT	Identity, credential and access management; least privilege access for user, administrative and non-person accounts; secure administration
ISO/IEC 27001:2022 Annex A	5.15 access control; 5.16 identity management; 5.18 access rights; 6.5 responsibilities after termination; 8.2 privileged access; 8.5 secure authentication
SOC 2 trust services criteria	CC6 logical and physical access controls
Australian Privacy Act, APP 11	Access controls as a reasonable step to protect personal information

General guidance, not legal advice. References to standards show where this resource aligns; using it does not make an organisation compliant or certified. Check your specific obligations with a qualified adviser. Regulatory references checked October 2026.

© 2026 Rev-IQ. Free to use and adapt.